

## Data

A collection of facts that can be examined, considered, and used for decision-making. Although data may be physical, the CIS Controls primarily provide protection for digital data that may be stored, transferred, and processed by enterprise assets.

## Data Exposure

An unintentional data breach.

## Database

Organized collection of data, generally stored and accessed electronically from a computer system. Databases can reside remotely or on-site. Database Management Systems (DBMSs) are used to administer databases, and are not considered part of a database for this document.

## Devices

Devices are enterprise assets (data processing and storage assets), end-user devices, portable devices, mobile devices, servers, Internet of Things and non-computing devices, network devices, and removable media. Devices may exist in physical spaces, virtual infrastructure, or cloud-based environments. Devices can remotely connect to these systems.

## Documentation

Policies, processes, procedures, plans, diagrams, and other written material (e.g., compliance reports) either physical or digital. Examples include methods of governance for an enterprise, processes that users follow, or describe network architecture.

## Dwell Time

The period of time between an initial attack and the detection of an intrusion when an attacker has unauthorized access to the data and the environment.

## End-user devices

Information technology (IT) assets used among members of an enterprise during work or off-hours. End-user devices include desktops and workstations, as well as portable and mobile devices such as laptops, smartphones, and tablets. For the purpose of this document, end-user devices are a subset of enterprise assets.

## Enterprise

An enterprise is any business or organization that uses computer systems, networks, and devices.

## Enterprise assets

Assets with the potential to store or process data. For the purpose of this document, enterprise assets include end-user devices, network devices, non-computing/Internet of Things (IoT) devices, and servers, in virtual, cloud-based, and physical environments.

## Externally-exposed applications

Refers to applications that are public facing and discoverable through reconnaissance and network scanning from the public internet outside of the enterprise's network.

## Externally-exposed enterprise assets

Refers to enterprise assets that are public facing and discoverable through domain name system reconnaissance and network scanning from the public internet outside of the enterprise's network.

## Firmware

Software stored within a device's non-volatile memory, such as ROM or flash memory, used to allow different types of hardware to communicate with the operating system. Firmware is often updated outside of the enterprise's operating system and application software update process.

## Govern

NIST CSF 2.0 Security Function Govern is defined as the organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored. The Govern Function provides outcomes to inform what an organization may do to achieve and prioritize the outcomes of the other five Functions in the context of its mission and stakeholder expectations. Governance activities are critical for incorporating cybersecurity into an organization's broader enterprise risk management (ERM) strategy. GOVERN addresses an understanding of organizational context; the establishment of cybersecurity strategy and cybersecurity supply chain risk management; roles, responsibilities, and authorities; policy; and the oversight of cybersecurity strategy.<sup>2</sup>

## Internal enterprise assets

Refers to non-public facing enterprise assets that can only be identified through network scans and reconnaissance from within an enterprise's network through authorized authenticated or unauthenticated access.

<sup>2</sup> NIST Reference Format for NIST Publications: <https://www.nist.gov/nist-research-library/reference-format-nist-publications>

## Internet of Things (IoT) and Non-computing Devices

Devices embedded with sensors, software, and other technologies. These devices may connect, store, and exchange data with other devices and systems. The device's connection to the internet can be intermittent, non-existent, or persistent. Examples of these devices include smart watches and other wearables, printers, smart screens, smart home devices, speakers, industrial control systems, and physical security sensors. For the purpose of this document, IoT and non-computing devices are a subset of enterprise assets.

## Library

A shareable pre-compiled codebase to include classes, procedures, scripts, configuration data, and more, used to develop software programs and applications. Libraries are designed to assist both the programmer and the programming language compiler in building and executing software more efficiently.

## Log Data

A computer-generated data file that records the events occurring within the enterprise. Examples of logs include: operating system, anti-malware detection, database, application, network, firewall, web server, or access control logs (e.g., electronic locks, alarm system).

## Mobile devices

Small, enterprise-issued end-user devices with intrinsic wireless capability, such as smartphones and tablets. For the purpose of this document, mobile devices are a subset of portable devices.

## Multi-factor authentication

Authentication using two or more different factors to achieve authentication. Factors include something you know (e.g., PIN, password), something you have (e.g., cryptographic identification device, token), or something you are (e.g., biometric).<sup>3</sup>

## Network

A network is a group of interconnected devices that exchange data. Network is a superset of network infrastructure and network architecture.

## Network Architecture

Refers to how a network is designed, both physically and logically. It defines how a network is organized, including the connections between devices and software as well as the data that is transmitted between them. This should include network architecture diagrams and security architecture diagrams.

## Network Asset

A group of interconnected devices that exchange data. Enterprises may operate one or more networks that are managed together or independently.

## Network Devices

Electronic devices required for communication and interaction between devices on a computer network. Network devices include wireless access points, firewalls, physical/virtual gateways, routers, and switches. These devices consist of physical hardware, as well as virtual and cloud-based devices. For the purpose of this document, network devices are a subset of enterprise assets. Note that network devices are listed under Enterprise Assets because they are managed much like other devices, however, they also play a dual role in the Network Asset Class when related to the communication over a network.

## Network Infrastructure

The collection of network resources that provide connectivity, management, business operations, and communication. It consists of hardware and software, systems and devices, and it enables computing and communication between users, services, applications, and processes. Network infrastructure can be in the cloud, physical, or virtual.

## Non-computing/Internet of Things (IoT) devices

Devices embedded with sensors, software, and other technologies for the purpose of connecting, storing, and exchanging data with other devices and systems over the internet. While these devices are not used for computational processes, they support an enterprise's ability to conduct business processes. Examples of these devices include printers, smart screens, physical security sensors, industrial control systems, and information technology sensors. For the purpose of this document, non-computing/IoT devices are a subset of enterprise assets.

<sup>3</sup> <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171r2.pdf>

## Operating system

Software on enterprise assets that manages computer hardware and software resources and provides common services for programs. Example operating systems include Windows, Ubuntu, MacOS, Android, and z/OS. Operating systems are considered a software asset.

## Phishing

A technique for attempting to acquire sensitive data, such as bank account numbers, through a fraudulent solicitation in email or on a website, in which the perpetrator masquerades as a legitimate business or reputable person.<sup>4</sup>

## Physical data

Data that is stored in physical documents or stored on physical types of removable devices (e.g., USB drives, tape backups). Physical data may be sensitive or not.

## Physical environment

Physical hardware parts that make up a network, including cables and routers. The hardware is required for communication and interaction between devices on a network.

## Plan

A plan implements policies and may include groups of policies, processes, and procedures.

## Policy

A policy is an official governance statement that outlines specific objectives of an information security program.

## Portable devices

Transportable, end-user devices that have the capability to wirelessly connect to a network. Portable devices can include laptops which may require external hardware for connectivity and mobile devices, such as smartphones and tablets. For the purpose of this document, portable devices are a subset of end-user devices.

## Pretexting

Part of a social engineering attack that involves inventing a scenario to convince the victim to divulge information that should not be divulged. The purpose of pretexting is to convince the victim of the legitimacy of the communication. The method of this type of attack can be through any communication method or medium.

## Procedure

A procedure is an ordered set of steps that must be followed to accomplish a specific task. It provides the approved way of performing an action in a specific technological and organizational environment.

## Process

A set of general tasks and activities to achieve a series of security-related goals.

## Remote devices

Any enterprise asset capable of connecting to a network remotely, usually from public internet. This can include enterprise assets such as end-user devices, network devices, non-computing/Internet of Things (IoT) devices, and servers.

## Remote file systems

Enable an application that runs on an enterprise asset to access files stored on a different asset. Remote file systems often make other resources, such as remote non-computing devices, accessible from an asset. The remote file access takes place using some form of local area network, wide area network, point-to-point link, or other communication mechanism. These file systems are often referred to as network file systems or distributed file systems.

## Removable media

Any type of storage device that can be removed from a computer while the system is running and allows data to be moved from one system to another. Examples of removable media include CDs, DVDs, Blu-ray Discs, external hard drives, SD cards, tape backups, diskettes, and USB drives.

## Script

Uncompiled code that requires a software environment to execute.

## Sensitive Data

Physical or digital data stored, processed, or managed by the enterprise that must be kept private, accurate, reliable, and available. If released or destroyed in an unauthorized manner, it would cause harm to the enterprise or its customers. These impacts may be due to a data breach or a violation of a policy, contract, or regulation.

<sup>4</sup> <https://tools.ietf.org/html/rfc4949>

## **Servers**

A device or system that provides resources, data, services, or programs to other devices on either a local area network or wide area network. Servers can provide resources and use them from another system at the same time. Servers can exist in datacenters, public/private/hybrid cloud environments, including temporal containers or serverless workloads. Examples of servers include web servers, application servers, mail servers, and file servers. For the purpose of this document, servers are a subset of enterprise assets.

## **Service accounts**

A service account is created specifically to run applications, services, and automated tasks on an operating system. Service accounts may also be created just to own data and configuration files. Each service account should be used for a specific service or function, and it should have an assigned owner who is responsible for how the account is used. Service accounts should not be used for general purpose computing.

## **Services**

Specialized programs that perform well-defined critical tasks for the operating system. Services often start with the operating system, run-in in the background, and can be stopped and started by users. Example services include managing network communications, users, file permissions, system security, and device interaction.

## **Service Provider**

Entity that offers platforms, software, and services to other enterprises. Examples include IT consultants, managed service provider (MSPs), Software as a Service (SaaS) platforms, and cloud service providers. Third-party providers and vendors are also considered Service Providers. These services may be paid or free. Some relationships may or may not require a contract or SLA in place. Examples include data analysis, traffic blocking, and similar services.

## **Social engineering**

Refers to a broad range of malicious activities accomplished through human interactions on various platforms, such as email or phone. It relies on psychological manipulation to trick users into making security mistakes or giving away sensitive information.

## **Software**

Sets of data and instructions used to direct a computer to complete a specific task. Software assets include operating systems and applications. Both may contain services, libraries, or Application Programming Interfaces (APIs).

## **Tailgating**

A physical security issue where an individual follows another into a secured area without properly authenticating or following established protocols for entering the area.

## **Third-Party Provider**

See Service Provider.

## **Users**

Employees, third-party vendors, contractors, service providers, consultants, or any other person who is authorized to access an enterprise asset. This also includes user, administrator, and service accounts.

## **User accounts**

An identity comprised of a set of credentials (e.g., username, password) that defines a user on a computer or computing system. A user account keeps track of a user's information and settings, controls the files, folders, and resources a user is allowed to access, as well as the tasks a user is allowed to perform. For the purpose of this document, user accounts refer to "standard" user accounts with limited privileges and are used for general tasks.

## **Virtual environment**

Simulates hardware to allow a software environment to run without the need to use a lot of actual hardware. Virtualized environments are used to make a small number of resources act as many with plenty of processing, memory, storage, and network capacity. Virtualization is a fundamental technology that allows cloud computing to work.

## **Workforce**

All individuals who are employed or engaged by an organization and have access to its information systems, assets, or resources. It includes all employees both on-site and remote, excluding service providers and consultants.

# Resources and References

**A Roadmap to the CIS Critical Security Controls:** <https://www.cisecurity.org/insights/white-papers/roadmap-cis-critical-security-controls>

---

**CIS Benchmarks®:** <http://www.cisecurity.org/cis-benchmarks/>

---

**CIS Controls Cloud Companion Guide:** <https://www.cisecurity.org/insights/white-papers/cis-controls-v8-1-cloud-companion-guide>

---

**CIS Controls Mappings:** <https://www.cisecurity.org/controls/resources?crc=other-security-frameworks>

---

**CIS Controls Navigator:** <https://www.cisecurity.org/controls/cis-controls-navigator>

---

**CIS Controls Policy Templates:** <https://www.cisecurity.org/controls/resources?crc=implementation-tools-guidance>

---

**CIS Controls Resources:** <https://www.cisecurity.org/controls/resources?crc=about-the-cis-critical-security-controls>

---

**CIS Community Defense Model (CDM):**  
<https://www.cisecurity.org/insights/white-papers/cis-community-defense-model-2-0>

---

**CIS Configuration Assessment Tool (CIS-CAT®):** <https://learn.cisecurity.org/cis-cat/>

---

**CIS Controls Assessment Specification:** <https://cas.docs.cisecurity.org/en/latest/>

---

**CIS Controls Industrial Control Systems Implementation Guide:** <https://www.cisecurity.org/insights/white-papers/cis-critical-security-controls-v8-1-industrial-control-systems-ics-guide>

---

**CIS Controls Internet of Things Companion Guide:**  
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

---

**CIS Controls Mobile Companion Guide:**  
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

---

**CIS Controls Self Assessment Tool (CSAT):** <https://www.cisecurity.org/controls/cis-controls-self-assessment-tool-cis-csat/>

---

**CIS Controls Telework and Small Office Network Security Guide:**

<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

---

**CIS CSAT Ransomware Business Impact Analysis (BIA) Tool:** <https://www.cisecurity.org/cis-securesuite/business-impact-analysis-tool>

---

**CIS WorkBench:** <https://www.cisecurity.org/insights/blog/how-to-get-up-and-running-with-cis-workbench>

---

**CIS Password Policy Guide:** <https://www.cisecurity.org/white-papers/cis-password-policy-guide>

---

**CIS Risk Assessment Method (RAM):**  
<https://www.cisecurity.org/insights/white-papers/cis-ram-risk-assessment-method>

---

**Cloud Security Alliance (CSA):** <https://cloudsecurityalliance.org/>

---

**Cost of Cyber Defense for IG1:** <https://www.cisecurity.org/controls/resources?crc=assess-and-measure>

---

**Council of Registered Security Testers (CREST) Cyber Security Incident Response Guide:**  
<https://www.crest-approved.org/wp-content/uploads/2022/04/CSIR-Procurement-Guide-1.pdf>

---

**EDUCAUSE:** <https://www.educause.edu/focus-areas-and-initiatives/policy-and-security/cybersecurity-program/awareness-campaigns>

---

**Establishing Essential Cyber Hygiene (v8.1):** <https://www.cisecurity.org/insights/white-papers/establishing-essential-cyber-hygiene-version-8-1>

---

**Guide to Asset Classes:** <https://www.cisecurity.org/insights/white-papers/guide-to-asset-classes-cis-critical-security-controls-v8-1>

---

**Guide to Implementation Groups (IG) - CIS Critical Security Controls v8.1:**  
<https://www.cisecurity.org/insights/white-papers/guide-implementation-groups-ig-cis-critical-security-controls-v8-1>

---

**International Organization for Standardization:** <https://www.iso.org/home.html>

---

**National Cyber Security Alliance (NCSA):** <https://staysafeonline.org/>

---

**National Cyber Security Centre (U.K.):** <https://www.ncsc.gov.uk/guidance/10-steps-user-education-and-awareness>

---



**National Institute of Standards and Technology (NIST®):** <https://www.nist.gov/>

---

**National Institute of Standards and Technology (NIST®) Cybersecurity Framework (CSF) 2.0:** <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

---

**National Institute of Standards and Technology (NIST®) Digital Identity Guidelines:** <https://pages.nist.gov/800-63-3/>

---

**National Institute of Standards and Technology (NIST®) FIPS 140-2:** <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-2.pdf>

---

**National Institute of Standards and Technology (NIST®) FIPS 140-3:** <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-3.pdf>

---

**National Institute of Standards and Technology (NIST®) National Checklist Program Repository:** <https://nvd.nist.gov/ncp/repository>

---

**National Institute of Standards and Technology (NIST®) SP 800-50 Infosec Awareness Training:** <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-50r1.pdf>

---

**National Institute of Standards and Technology (NIST®) SP 800-88r1—Guidelines for Media Sanitization:** <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>

---

**National Institute of Standards and Technology (NIST®) SP 800-126r3 The Technical Specification for the Security Content Automation Protocol (SCAP):** <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-126r3.pdf>

---

**National Institute of Standards and Technology (NIST®) SSDF:** <https://csrc.nist.gov/News/2020/mitigating-risk-of-software-vulns-ssdf>

---

**OWASP®:** <https://owasp.org/>

---

**OWASP® Penetration Testing Methodologies:** [https://www.owasp.org/index.php/Penetration\\_testing\\_methodologies](https://www.owasp.org/index.php/Penetration_testing_methodologies)

---

**PCI Security Standards Council:** [https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1\\_1.pdf](https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf)

---

**Privacy Companion Guide for Controls v8:** <https://www.cisecurity.org/insights/white-papers/cis-controls-v8-privacy-companion-guide>

---

**SAFECode Application Security Addendum:** <https://safecode.org/cis-controls/>

---

**SANS:** <https://www.sans.org/security-awareness-training/resources>

---

**SME Guide for Controls v8:** <https://www.cisecurity.org/insights/white-papers/implementation-guide-for-small-and-medium-sized-enterprises-cis-controls-ig1>

---

**The Software Alliance:** <https://www.bsa.org/reports/updated-bsa-framework-for-secure-software>

---

**Trailhead Training Courses for CIS Controls:** <https://www.cisecurity.org/controls/trailhead-training-courses>

---

**Verizon Data Breach Investigations Report:**  
<https://www.verizon.com/business/resources/reports/dbir/>



# Controls and Safeguards Index

## CONTROL 1

### Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments, to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

#### Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory

|                            |                                    |            |            |            |
|----------------------------|------------------------------------|------------|------------|------------|
| Asset Type: <b>Devices</b> | Security Function: <b>Identify</b> | <b>IG1</b> | <b>IG2</b> | <b>IG3</b> |
|----------------------------|------------------------------------|------------|------------|------------|

Establish and maintain an accurate, detailed, and up-to-date inventory of all enterprise assets with the potential to store or process data, to include: end-user devices (including portable and mobile), network devices, non-computing/IoT devices, and servers. Ensure the inventory records the network address (if static), hardware address, machine name, enterprise asset owner, department for each asset, and whether the asset has been approved to connect to the network. For mobile end-user devices, MDM type tools can support this process, where appropriate. This inventory includes assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments. Additionally, it includes assets that are regularly connected to the enterprise’s network infrastructure, even if they are not under control of the enterprise. Review and update the inventory of all enterprise assets bi-annually, or more frequently.

#### Safeguard 1.2: Address Unauthorized Assets

|                            |                                   |            |            |            |
|----------------------------|-----------------------------------|------------|------------|------------|
| Asset Type: <b>Devices</b> | Security Function: <b>Respond</b> | <b>IG1</b> | <b>IG2</b> | <b>IG3</b> |
|----------------------------|-----------------------------------|------------|------------|------------|

Ensure that a process exists to address unauthorized assets on a weekly basis. The enterprise may choose to remove the asset from the network, deny the asset from connecting remotely to the network, or quarantine the asset.

### Safeguard 1.3: Utilize an Active Discovery Tool

|                            |                                  |                       |
|----------------------------|----------------------------------|-----------------------|
| Asset Type: <b>Devices</b> | Security Function: <b>Detect</b> | <b>IG2</b> <b>IG3</b> |
|----------------------------|----------------------------------|-----------------------|

Utilize an active discovery tool to identify assets connected to the enterprise's network. Configure the active discovery tool to execute daily, or more frequently.

### Safeguard 1.4: Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory

|                            |                                    |                       |
|----------------------------|------------------------------------|-----------------------|
| Asset Type: <b>Devices</b> | Security Function: <b>Identify</b> | <b>IG2</b> <b>IG3</b> |
|----------------------------|------------------------------------|-----------------------|

Use DHCP logging on all DHCP servers or Internet Protocol (IP) address management tools to update the enterprise's asset inventory. Review and use logs to update the enterprise's asset inventory weekly, or more frequently.

### Safeguard 1.5: Use a Passive Asset Discovery Tool

|                            |                                  |            |
|----------------------------|----------------------------------|------------|
| Asset Type: <b>Devices</b> | Security Function: <b>Detect</b> | <b>IG3</b> |
|----------------------------|----------------------------------|------------|

Use a passive discovery tool to identify assets connected to the enterprise's network. Review and use scans to update the enterprise's asset inventory at least weekly, or more frequently.

## CONTROL 2

# Inventory and Control of Software Assets

Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

### Safeguard 2.1: Establish and Maintain a Software Inventory

|                             |                                    |                                  |
|-----------------------------|------------------------------------|----------------------------------|
| Asset Type: <b>Software</b> | Security Function: <b>Identify</b> | <b>IG1</b> <b>IG2</b> <b>IG3</b> |
|-----------------------------|------------------------------------|----------------------------------|

Establish and maintain a detailed inventory of all licensed software installed on enterprise assets. The software inventory must document the title, publisher, initial install/use date, and business purpose for each entry; where appropriate, include the Uniform Resource Locator (URL), app store(s), version(s), deployment mechanism, decommission date, and number of licenses. Review and update the software inventory bi-annually, or more frequently.